TPI Entrega N.º 4 – Procesos, Trabajo Colaborativo y Control Integrador

Nov 1, 2026 · @ELIANA

Carátula

Repositorio público de GitHub: gokuheine/tpi-deteccion-amenaza-meli: documentacion

Tablero de gestion https://github.com/users/gokuheine/projects/5/views/1

Dato	Detalle
Institución	Universidad Tecnológica Nacional
Carrera	Tecnicatura Universitaria en Programación a Distancia (TUP AD)
Asignatura	Organización Empresarial
Trabajo	TPI – Entrega N.º 4: Procesos, Trabajo Colaborativo y Control Integrador
Alumna	Celentano Eliana
Comisión	04
Cuerpo docente	Prof. Gabriela Martínez (titular); Prof. Carolina Bruno, Prof. Mario Raúl López, Prof. Andrea Ramos (adjuntos)
Empresa	Mercado Libre – Área de Desarrollo
Proyecto	Software de detección de amenazas de seguridad

Hilo conductor de las cuatro entregas

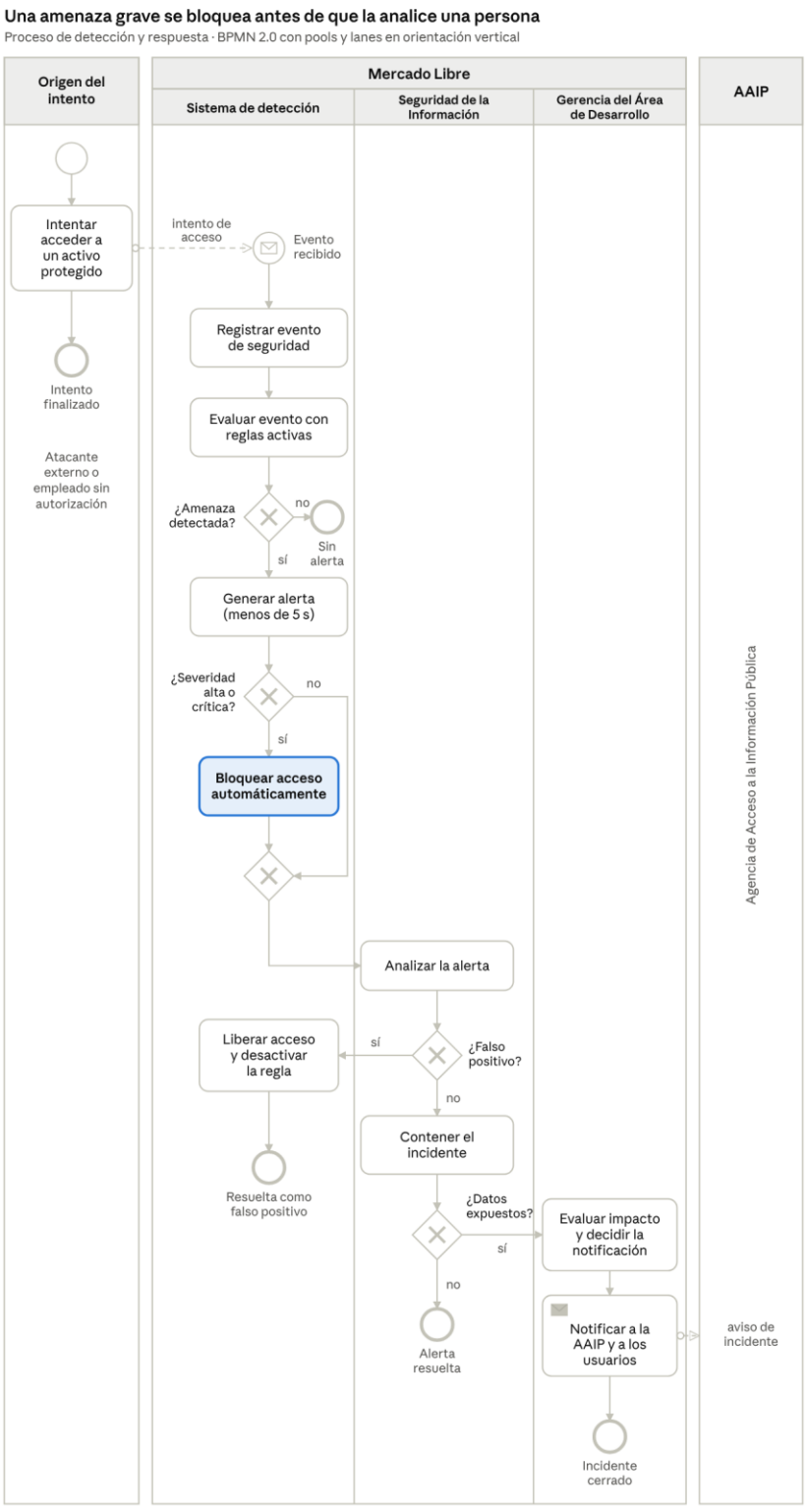
Esta entrega cierra el TPI y consolida las tres anteriores, que se adjuntan a continuación en el PDF final.

- **Entrega 1** modeló a Mercado Libre como sistema abierto (TGS) y mostró que sumar un módulo de detección, en ese caso de vendedores sospechosos, reconfigura otras áreas de la empresa.
- **Entrega 2** llevó esa misma lógica a un proyecto concreto del Área de Desarrollo: un software que detecta intrusiones externas y accesos internos no autorizados a las bases de datos de usuarios. Definió el FODA, los objetivos SMART, cinco metas cuantitativas y un Gantt de 27 semanas.
- **Entrega 3** diseñó la estructura (organigrama con Seguridad de la Información como staff) y los datos (ACTIVO_PROTEGIDO, EVENTO_SEGURIDAD, REGLA_DETECCION y ALERTA).
- **Entrega 4** describe cómo funciona el proceso que el software automatiza (BPMN), cómo se organiza el trabajo (Git, GitHub y backlog) y cómo se controla el resultado (indicadores ligados a las metas de la Entrega 2).

El cambio de foco entre la Entrega 1 y la 2 es deliberado: ambos son subsistemas de detección que reutilizan datos de la organización, pero el segundo protege un activo más crítico, los datos personales de los usuarios.

1. Modelado del proceso de negocio (BPMN)

El proceso modelado es la detección y respuesta ante un intento de acceso no autorizado a un activo protegido de Mercado Libre. Es un modelo *to-be*: muestra cómo funcionará el proceso con el software, que automatiza el registro del evento, su evaluación contra las reglas, la alerta y el bloqueo.



Proceso de detección y respuesta ante un acceso no autorizado · BPMN 2.0 · 4 pools/lanes de Mercado Libre y 2 pools externos

Las amenazas de severidad alta o crítica se bloquean automáticamente antes de llegar al analista; las demás solo generan una alerta. Cada camino termina en un evento de fin distinto, y eso permite contar los resultados con el campo `estado` de ALERTA.

Pools y lanes

Elemento	Tipo BPMN	Qué representa
Origen del intento	Pool (actor externo)	Atacante externo o empleado sin autorización. El empleado pertenece a Mercado Libre, pero se lo modela fuera porque actúa por fuera de su rol autorizado; el sistema solo recibe su intento como mensaje
Mercado Libre	Pool (organización)	Contiene las tres lanes del proceso
Sistema de detección	Lane (comportamiento automatizado)	Tareas que el software ejecuta sin intervención humana (tareas 9 a 13 del Gantt)
Seguridad de la Información	Lane (rol interno)	Área de staff del organigrama de la Entrega 3; analiza cada alerta
Gerencia del Área de Desarrollo	Lane (rol interno)	Autoridad lineal del organigrama; decide la notificación externa cuando hay datos expuestos
AAIP	Pool de caja negra	Autoridad de control de la Ley 25.326; recibe el aviso y su proceso interno no se modela

Compuertas de decisión (exclusivas)

1. **¿Amenaza detectada?** Si ninguna regla dispara, el evento queda registrado sin alerta. Es el flujo estándar de la mayoría de los eventos.
2. **¿Severidad alta o crítica?** Si la respuesta es sí, el sistema bloquea el acceso (`accion_automatica = bloqueo`); si no, solo notifica. Una compuerta de unión vuelve a juntar ambos caminos antes del análisis.
3. **¿Falso positivo?** Si la respuesta es sí, el sistema libera el acceso y desactiva la regla (`activa = false`). Este camino alimenta el indicador de falsos positivos y corresponde a la HU-02.
4. **¿Datos expuestos?** Si la respuesta es sí, la Gerencia evalúa el impacto y notifica a la AAIP y a los usuarios. La Ley 25.326 no impone esa notificación de forma expresa, pero la Resolución AAIP 47/2018 la recomienda (IAPP); por eso se modela como buena práctica.

El modelo editable se guarda en el repositorio (`docs/bpmn/proceso-deteccion-respuesta.bpmn`) y se abre en bpmn.io con orientación horizontal.

2. Entorno colaborativo y control de versiones (Git y GitHub)

La documentación técnica del proyecto vive en un repositorio público. Ningún cambio llega a la rama `main` sin pasar por una rama secundaria y un Pull Request revisado. La regla aplica a la documentación

del TPI lo mismo que se le exigiría al código del software en Mercado Libre: trazabilidad de cada cambio y control previo a la integración.

Estructura del repositorio

Ruta	Contenido
`README.md`	Portada: título, descripción del sistema, autora, enlaces, indicadores y Declaración de Uso de IA
`docs/entregas/`	PDF de las Entregas 1, 2 y 3
`docs/bpmn/`	Modelo del proceso (`.bpmn`, editable en bpmn.io) y su imagen exportada (`.png`)
`docs/datos/diccionario-datos.md`	Diccionario de datos de la Entrega 3
`docs/control/indicadores.md`	Indicadores de control y estándares de desempeño

Estrategia de ramas

Se usa un flujo de ramas por tarea (*feature branch workflow*): `main` siempre contiene la versión aprobada, y cada tarea se trabaja en una rama propia que se integra mediante un Pull Request.

Rama	Propósito	Se integra con
`main`	Versión aprobada de la documentación	—
`docs/readme-portada`	Portada del proyecto en el README	PR #7 (cierra issue #4)
`docs/modelo-bpmn`	Modelo BPMN del proceso de detección y respuesta	PR #8 (cierra issue #5, con revisión de pares)
`docs/indicadores-control`	Indicadores de control y Declaración de Uso de IA	PR #9 (cierra issue #6)

Convención de mensajes de commit

Los mensajes siguen el formato *Conventional Commits*: `tipo(alcance): descripción en infinitivo`. El tipo indica la clase de cambio y el alcance, la parte del proyecto afectada. Por ejemplo:

- `docs(readme): agregar portada con descripción del sistema e integrantes`
- `docs(bpmn): modelar proceso de detección y respuesta ante accesos no autorizados`
- `fix(bpmn): agregar compuerta de falso positivo en la lane de Seguridad de la Información`
- `docs(control): definir indicadores ligados a las metas de la Entrega 2`

Se evitan mensajes como "cambios" o "update", porque no le dicen a quien revisa qué se modificó ni por qué.

Pull Request con autorrevisión

El TPI se realiza de forma individual, modalidad aceptada por la cátedra, así que la autora es también quien revisa. El PR #8 (`docs/modelo-bpmn` → `main`) se usa igual como punto de control: el cambio no entra a `main` hasta que se revisa en el propio PR. GitHub no permite aprobar un PR propio, por lo que la revisión queda registrada como comentario. El circuito es:

1. La autora abre el PR, describe el cambio y lo vincula con su issue (`Closes #5`). En GitHub, issues y PR comparten numeración: por eso los PR empiezan en #7, después de los seis issues del tablero.
2. En la pestaña *Files changed*, la autora revisa el diagrama contra la consigna (pools, lanes y compuertas) y deja un comentario de revisión con lo que controló y lo que hay que corregir.
3. Corrige en la misma rama con un nuevo commit, que se suma al PR, y deja constancia en el hilo.
4. Con la revisión cerrada, hace el *merge* a `main` y borra la rama.

Evidencia: [insertar captura del PR #8 con el comentario de revisión, el commit de corrección y el merge] · [insertar captura del grafo de ramas: Insights → Network]

3. Gestión del backlog ágil

El backlog se gestiona en un tablero de **GitHub Projects** con tres columnas: Por Hacer, En Progreso y Listo. Cada Historia de Usuario es un issue del repositorio, y cada PR que la trabaja la menciona. Así el tablero refleja la actividad real del repositorio y no una lista aparte.

Aclaración: las Entregas 1 a 3 no incluían Historias de Usuario en formato formal, por lo que se formalizan en esta entrega. Se derivan de las metas de la Entrega 2 y de las entidades de la Entrega 3, para que cada una tenga un criterio de aceptación medible.

Historias de Usuario

HU-01 – Alerta inmediata (issue #1). Como analista de Seguridad de la Información, quiero recibir una alerta en menos de 5 segundos cuando se detecta un acceso no autorizado a una base de datos de usuarios, para contener el incidente antes de que se filtren datos.

- Criterio de aceptación: el campo `tiempo_respuesta_seg` de ALERTA es menor a 5 en el 95 % de las alertas de la prueba de carga (meta 2).
- Criterio de aceptación: si la regla tiene severidad alta o crítica, el sistema bloquea el acceso antes de notificar (`accion_automatica = bloqueo`).

HU-02 – Gestión de falsos positivos (issue #2). Como analista de Seguridad de la Información, quiero marcar una alerta como falso positivo y desactivar la regla que la originó, para no bloquear a usuarios legítimos.

- Criterio de aceptación: al marcar `falso_positivo = true`, el acceso bloqueado se libera y la alerta pasa a estado "resuelta".
- Criterio de aceptación: la regla puede pasar a `activa = false` sin borrar su historial de alertas, y la tasa de falsos positivos queda por debajo del 2 % (meta 1).

HU-03 – Panel de control (issue #3). Como coordinador del proyecto, quiero ver en un panel qué activos están monitoreados y los indicadores de detección, para controlar el avance hacia las metas de cobertura y precisión.

- Criterio de aceptación: el panel muestra el porcentaje de activos con `monitoreado = true` sobre el total relevado (meta 5).
- Criterio de aceptación: el panel muestra la tasa de detección, la tasa de falsos positivos y el tiempo de alerta con el semáforo de la sección 4.

Estado del tablero

El software no se programa dentro del TPI, así que "Listo" significa que la historia quedó especificada, con criterios de aceptación, y modelada en el BPMN. Las tareas de documentación (issues #4 a #6) siguen el ciclo completo: se cierran solas cuando se integra su PR.

Issue	Ítem	Tipo	Estado	Se vincula con
#1	HU-01 Alerta inmediata	Historia de Usuario	Listo	BPMN (lane Sistema), meta 2
#2	HU-02 Gestión de falsos positivos	Historia de Usuario	En Progreso	BPMN (lane Seguridad de la Información), meta 1
#3	HU-03 Panel de control	Historia de Usuario	Por Hacer	Sección 4, meta 5
#4	Portada del README	Tarea	Listo	PR #7
#5	Modelo BPMN	Tarea	Listo	PR #8
#6	Indicadores y Declaración de IA	Tarea	En Progreso	PR #9

Evidencia: [insertar captura del tablero con las tres columnas] · [insertar captura del historial de un issue que muestre el cambio de estado]

4. Mecanismos de control: indicadores y estándares de desempeño

Los estándares de control son las cinco metas de la Entrega 2, y cada indicador se calcula con campos del diccionario de datos de la Entrega 3. Así el control no depende de opiniones: el propio sistema genera los datos con los que se lo audita.

El proceso de control aplicado al proyecto

1. **Establecer estándares:** las metas cuantitativas de la Entrega 2 (95 % de detección, 2 % de falsos positivos, alerta en menos de 5 s, 10.000 eventos por segundo, 100 % de cobertura, 27 semanas).
2. **Medir el desempeño:** los registros de ALERTA, EVENTO_SEGURIDAD y ACTIVO_PROTEGIDO, más los resultados de las pruebas de las semanas 17 a 20.
3. **Comparar con el estándar:** el panel de monitoreo (HU-03) aplica un semáforo a cada indicador.

4. **Corregir desvíos:** cada indicador tiene una acción correctiva y un responsable según el organigrama.

Indicadores

Indicador	Fórmula	Estándar	Datos de origen	Tipo de control	Acción correctiva ante desvío
Tasa de detección	Ataques simulados detectados / ataques simulados lanzados	≥ 95 %	ALERTA vs. registro de pruebas de penetración	Retroalimentación	Analistas y desarrolladores revisan las REGLA_DETECCION que no dispararon
Tasa de falsos positivos	Alertas con `falso_positivo = true` / total de alertas	≤ 2 %	ALERTA	Concurrente	Seguridad de la Información desactiva o ajusta la regla (`activa = false`)
Tiempo de alerta	Percentil 95 de `tiempo_respuesta_seg`	< 5 s	ALERTA	Concurrente	Desarrolladores optimizan el módulo de alertas (tarea 13)
Capacidad de procesamiento	Eventos registrados por segundo; eventos recibidos − eventos registrados	≥ 10.000/s y 0 pérdidas	EVENTO_SEGURIDAD	Preventivo (prueba de carga antes del despliegue)	Se escala la infraestructura antes del piloto (tarea 20)
Cobertura	Activos con `monitoreado = true` / activos relevados	100 %	ACTIVO_PROTEGIDO	Retroalimentación	El coordinador gestiona el acceso con el área responsable del activo
Cumplimiento del plazo	Semanas de atraso en tareas del camino crítico	0 semanas	Gantt y tablero	Concurrente	El coordinador reasigna recursos de tareas con holgura (por ejemplo, la tarea 7)

Indicador	Fórmula	Estándar	Datos de origen	Tipo de control	Acción correctiva ante desvío
Integración controlada	PR integrados con comentario de revisión / total de PR integrados	100 %	Historial de GitHub	Preventivo	Se protege la rama `main` para *que todo cambio entre por un PR*

Para el tiempo de alerta se usa el percentil 95 y no el promedio. Un promedio de 3 s puede esconder alertas de 20 s, que son justamente las que llegan tarde a un ataque real.

Semáforo del panel

Estado	Criterio	Qué significa
Verde	Cumple el estándar	Se sigue monitoreando
Amarillo	A menos del 10 % del límite (por ejemplo, falsos positivos entre 1,8 % y 2 %)	Se analiza la causa antes de que haya desvío
Rojo	No cumple el estándar	Se aplica la acción correctiva y se registra en un issue

El margen del 10 % para el amarillo es una propuesta propia y se puede ajustar después del piloto.

El panel como sistema de información

El mismo dato sirve a los tres niveles de la organización, con distinto grado de detalle:

- **Operativo:** el analista de Seguridad de la Información ve cada alerta en tiempo real y decide sobre ella.
- **Táctico:** el coordinador del proyecto ve los indicadores semanales y el avance del Gantt.
- **Estratégico:** la Gerencia del Área de Desarrollo ve la tendencia mensual y decide inversiones, por ejemplo sumar especialistas en ciberseguridad (debilidad del FODA).

5. Declaración de Uso de IA

Se utilizó un asistente de IA generativa (Claude, de Anthropic) para estructurar esta entrega. La veracidad y la coherencia conceptual son responsabilidad de la alumna, que revisó y corrigió el resultado según se detalla abajo. La misma declaración figura en el `README.md` del repositorio.

Propósitos

- Proponer la estructura del documento y del repositorio a partir de la consigna.
- Borrador del modelo BPMN (pools, lanes y compuertas) y del archivo `.bpmn`.
- Redacción preliminar de las Historias de Usuario, los indicadores de control y el README.
- Detección de inconsistencias entre las Entregas 1, 2 y 3.

Prompts utilizados y por qué

Prompt (resumen)	Por qué se formuló así
Se pegó la consigna completa de la Entrega 4, con la rúbrica	Para que la estructura respondiera a los cuatro puntos y a los criterios de evaluación, y no a una plantilla genérica
Se compartieron las Entregas 1, 2 y 3	Para que el BPMN, las Historias de Usuario y los indicadores usaran los datos ya presentados (metas, organigrama, entidades) y no datos inventados
[completar con otros prompts propios]	[completar]

Verificaciones y correcciones humanas

[Completar con lo que efectivamente revisaste y cambiaste. Por ejemplo: qué parte del BPMN modificaste en bpmn.io, qué criterio de aceptación reescribiste, qué dato comparaste con la fuente.]

- [corrección 1]
- [corrección 2]
- [corrección 3]

Riesgos del modelo que se controlaron

- **Datos inventados:** se exigió que cada número saliera de las entregas anteriores; los umbrales nuevos, como el amarillo del semáforo, se marcan como propuesta propia.
- **Afirmaciones legales:** la notificación a la AAIP se presenta como recomendación de la Resolución AAIP 47/2018 y no como obligación de la Ley 25.326, porque la ley vigente no la impone de forma expresa.
- **Contenido genérico:** cada sección se vincula con una entrega anterior, para que la propuesta tenga contexto propio de Mercado Libre.